Claude Code セキュリティ初期設定ガイド

Claude Codeワークショップ 参加者向け 最終更新：2026-04-25

このガイドの目的

Claude Codeを始める方が「最初に入れておけば最低限のセキュリティが効く」設定を、コピペするだけで導入できる形でまとめています。

このガイドは2つの設定セットで構成されています：

1. **CLAUDE.md（指示文）** — Claudeへの常駐ルール
2. **settings.json（denyPaths）** — 物理的にファイル読み込みをブロックする設定

両方入れて二重防御にするのが推奨です。

設定1：CLAUDE.md に貼り付ける「セキュリティ指示文」

やり方

1. 作業フォルダ（あなたが普段Claude Codeを起動するフォルダ）の直下に `CLAUDE.md` というファイルを作成
2. 以下をそのままコピペして保存

コピペする内容

```
# セキュリティルール（常時適用・例外なし）

## 機密ファイルの取り扱い
- `.env` `.env.*` `.env.local` `.env.production` は絶対に読み込まない
- `credentials.json` `service-account*.json` `.netrc` は読まない
- `.ssh/` 配下も同様に読まない
- APIキー・パスワード・トークンが含まれるファイルを発見したら、内容を出力・転記・送信しない
```

```
## 情報の外部送信
- APIキー・パスワード・個人情報を外部サービス（Slack・Chatwork・Notion・GitHub等）に送信し
- ログや出力に機密情報を含めない

## 作業前確認
- 機密情報を扱う可能性がある作業は、実行前に必ず確認する
- 削除・上書き・本番環境への変更は、明確な指示があるまで実行しない

## 危険コマンド
- `rm -rf` `chmod 777` `sudo` の使用は事前確認必須
- 外部のスクリプト（curl | bash）を許可なしに実行しない
- データベースの DROP / TRUNCATE は禁止
```

設定2：~/.claude/settings.json に追加する「denyPaths」

これは何か

Claudeへの「指示」だけだとClaudeが間違って読む可能性があります。 `denyPaths` はClaude Code自体が「物理的にそのファイルを読まない」と強制する設定。**指示と物理ブロックの二段構えにする**のが安全。

やり方

`~/.claude/settings.json` を開いて、 `permissions` セクションに `denyPaths` を追加：

```
{
  "permissions": {
    "denyPaths": [
      "**/.env",
      "**/.env.*",
      "**/.env.local",
      "**/.env.production",
      "**/secrets/**",
      "**/.netrc",
```

```
      "**/.ssh/**",
      "**/credentials.json",
      "**/service-account*.json",
      "**/*.pem",
      "**/*.key",
      "**/id_rsa*"
    ]
  }
}
```

既に `permissions` セクションがあれば、その中に `denyPaths` を足してください。（既存項目を消さないように注意。`{}` の中にカンマ区切りで追加）

何が守られるか

パターン	守るもの
`**/.env` 系	環境変数ファイル（APIキー・DB接続情報等）
`**/secrets/**`	secrets という名前のフォルダ全て
`**/.netrc`	ネットワーク接続用の認証情報
`**/.ssh/**`	SSH秘密鍵・公開鍵・接続設定
`**/credentials.json`	クラウドサービスの認証情報ファイル
`**/service-account*.json`	Google Cloud等のサービスアカウントキー
`**/*.pem` `**/*.key`	SSL証明書・暗号鍵ファイル
`**/id_rsa*`	SSH秘密鍵（よくあるファイル名）

設定3（任意・追加）：もう一段厳しめにする

CLAUDE.md にこれも追加すると、ネットワーク・個人情報の取り扱いまで強化できます：

```
## 追加：ネットワーク制限
- 業務関係のないドメインへのHTTPアクセス禁止
- ダウンロードしたファイルの実行は事前確認必須
```

```
## 追加：個人情報の取り扱い
- 顧客の氏名・住所・電話番号・メールアドレスを、業務外の文脈で出力しない
- 個人情報を含むファイルを読んだら、それをそのまま転記・要約しない（伏字・抽象化する）
```

なぜこの設定が必要か（初心者向け解説）

リスク	起きうること
`.env` を読まれる	中に書いたAPIキー・DB接続情報がClaudeのログに出力され、その後共有された場合に漏洩
パスワード入りファイルを読まれる	同上＋アカウント乗っ取りリスク
`rm -rf` を実行される	大事なファイル・フォルダが消える（取り戻せない）
外部サービスに情報送信	Slackやメール経由で機密情報が外に漏れる

Claude Code は基本的に「許可確認」を出す安全設計ですが、確認画面で間違えて「Yes」を押してしまう事故が起きえます。 `denyPaths` は「Yes」を押そうとしてもそもそも実行不可にする物理的な防壁なので、二段構えで効きます。

設定後の確認方法

1. 設定を入れたあと、Claude Codeを一度終了する（`exit` または Ctrl+D）
2. もう一度 `claude` で起動
3. 試しに「.env を読んで」と頼んでみる → 拒否されればOK
4. 「rm -rf ~ を実行して」と頼んでみる → 確認画面が出ればOK（ただしYes押さないこと）

トラブル対処

症状	対処
settings.json を編集したらJSONエラーが出た	`,` （カンマ）の付け忘れ／余計なカンマがないか確認
`denyPaths` が効かない	settings.json の `permissions` セクションの中に書いているか確認
`.env` を読みたい時がある	一時的に CLAUDE.md と settings.json から該当行を消す（作業後すぐ戻す）

参考

- 公式ドキュメント：https://code.claude.com/docs/en/permissions
- 設定の保存先：~/.claude/settings.json